Tópicos Avançados em Novas Tecnologias

Automação e CI/CD parte 2

Prof. Diego Cardoso Borda Castro

GitHub-hosted runners

- São máquinas fornecidas pelo GitHub que executam seus workflows automaticamente
  - Ambiente já pronto (Ubuntu, Windows, macOS)
  - Você não gerencia infraestrutura
  - Cada execução começa “limpa” (stateless)
  - Limitações de tempo, CPU e memória
  - Cobrança por minutos

GitHub-hosted runners

- Limites por mês
  - Públicos: pode rodar à vontade
  - Privados: 2.000 minutos/mês
    - Reseta todo mês
    - Linux: custo normal
    - Windows/macOS: consome mais minutos
  - Máximo: 6 horas por job
  - Até 20 jobs simultâneos no plano Free

Self Hosted

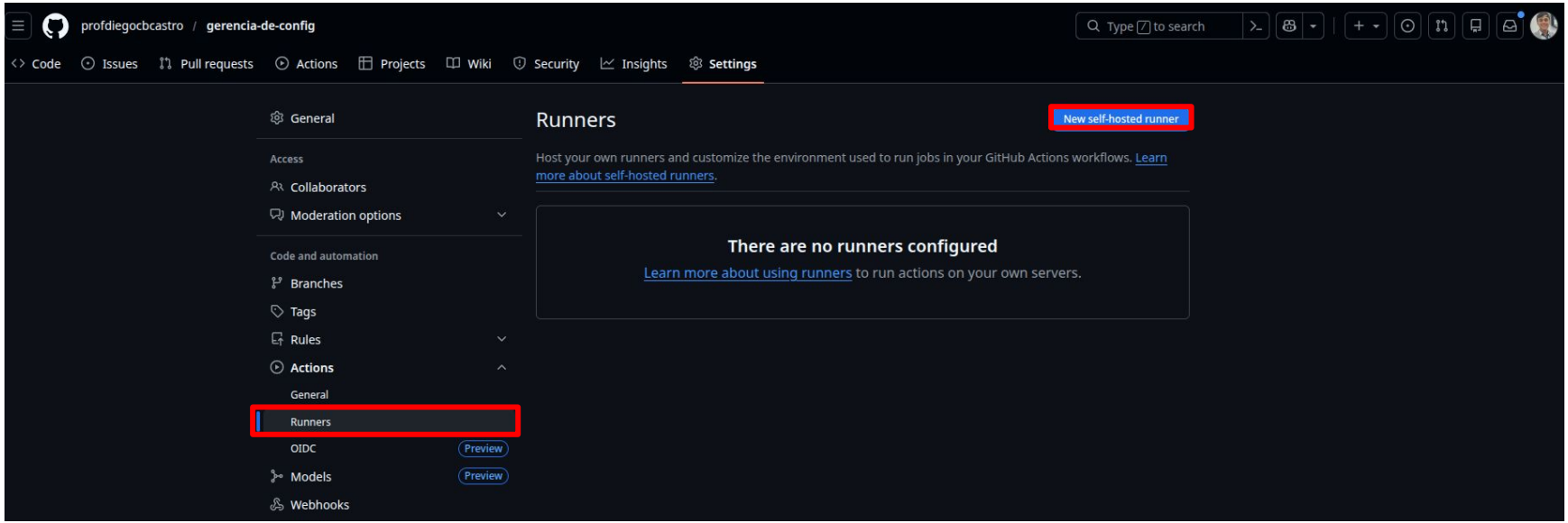
- Você mesmo configura a máquina que vai rodar o pipeline
  - Um servidor na sua empresa
  - Uma VM na nuvem (AWS, Azure, etc.)
  - Até sua própria máquina local
  - Vantagens
    - Máquinas mais potentes (GPU, muita RAM, etc)
    - Builds muito mais rápidos
    - Só utilize com cuidado! Pois você que deve garantir seu ambiente

Self Hosted

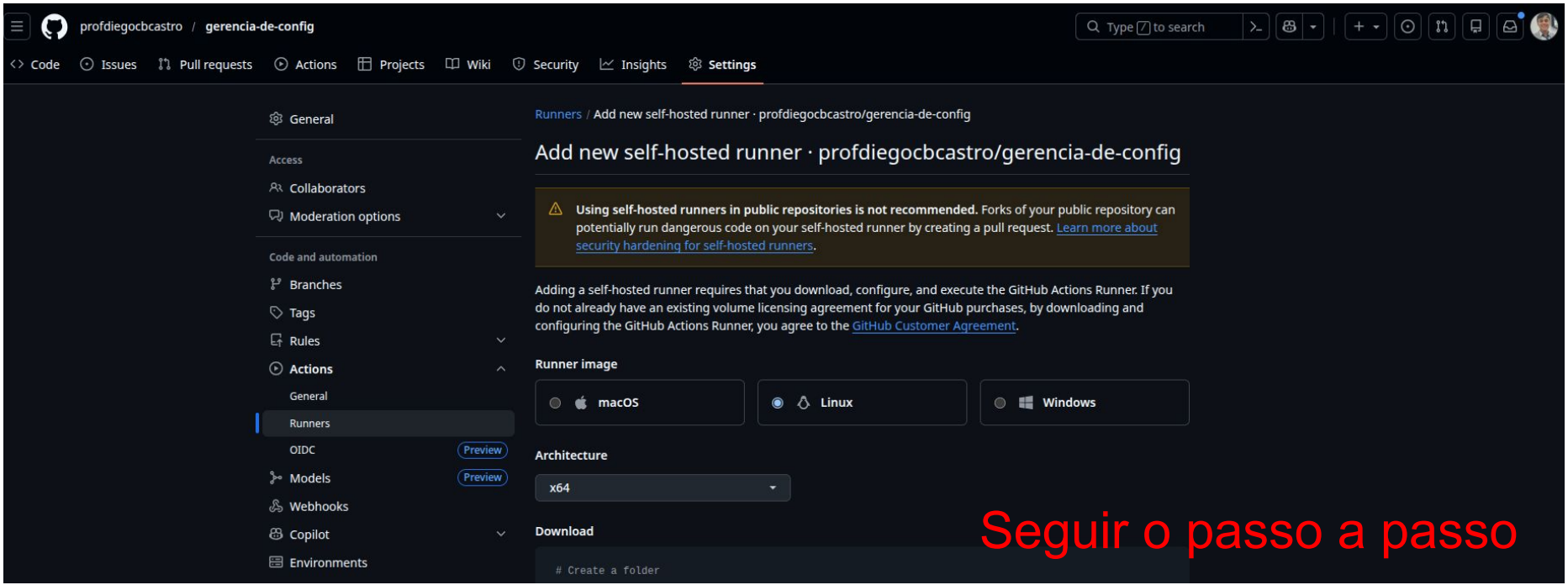
https://docs.github.com/pt/actions/reference/runners/self-hosted-runners

- O computador host deve ser capaz de fazer conexões HTTPS de saída pela porta 443
  - Sua máquina que acessa o github
- O computador host deve ser capaz de se comunicar com os domínios do GitHub
  - Firewall

Self Hosted


profdiegocbcastro / gerencia-de-config
Type / to search
Code
Issues
Pull requests
Actions
Projects
Wiki
Security
Insights
Settings
General
Access
Collaborators
Moderation options
Code and automation
Branches
Tags
Rules
Actions
General
Runners
OIDC
Preview
Models
Preview
Webhooks
Runners
New self-hosted runner
Host your own runners and customize the environment used to run jobs in your GitHub Actions workflows. Learn more about self-hosted runners.
There are no runners configured
Learn more about using runners to run actions on your own servers.

Self Hosted



Seguir o passo a passo

Self Hosted

```
~/actions-runner
./config.sh --url https://github.com/profdiegocbcastro/gerencia-de-config --token BP2WX4OVUIZFH3QJBC76DVT
JZKUVW

--------------------------------------------------------------------------------
|        ____ _ _   _   _       _          _     _ _                        |
|       / ___(_) |_| | | |_   _| |__      / \   ___| |_(_) ___  _ __  ___     |
|      | |  _| | __| |_| | | | | '_ \    / _ \ / __| __| |/ _ \| '_ \/ __|    |
|      | |_| | | |_|  _  | |_| | |_) |  / ___ \ (__| |_| | (_) | | | \__ \    |
|       \____|_|\__|_| |_|\__,_|_.__/  /_/   \_\___|\__|_|\___/|_| |_|___/    |
|                                                                              |
|                       Self-hosted runner registration                        |
|                                                                              |
--------------------------------------------------------------------------------

# Authentication


√ Connected to GitHub

# Runner Registration

Enter the name of the runner group to add this runner to: [press Enter for Default]

Enter the name of runner: [press Enter for diego-XPS-13-9300] maquina-pessoal

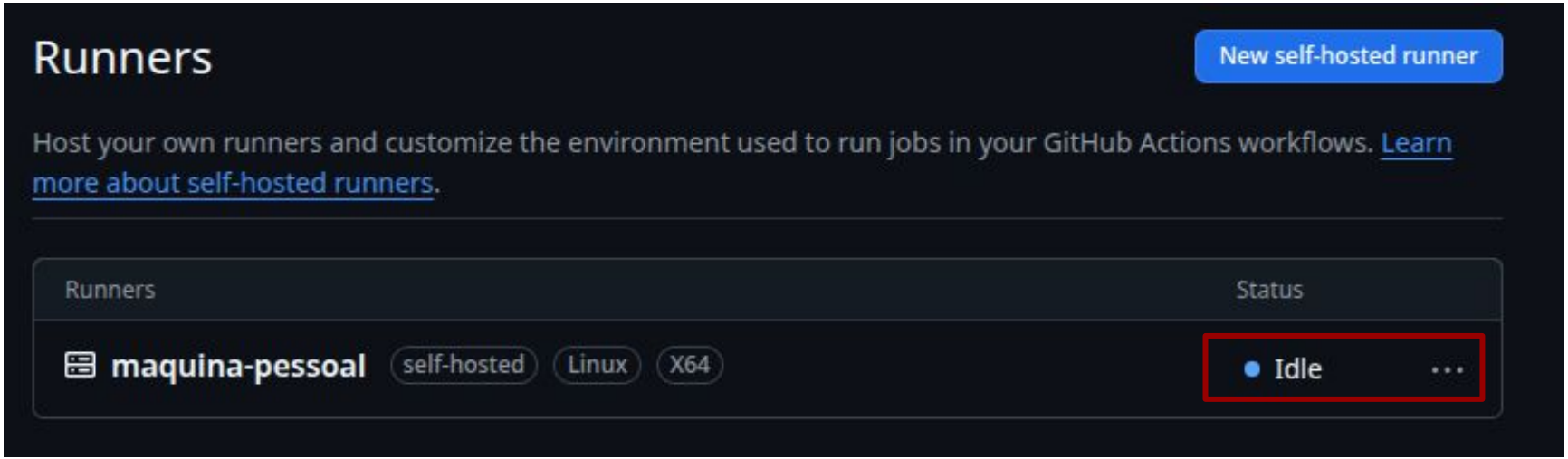
This runner will have the following labels: 'self-hosted', 'Linux', 'X64'
Enter any additional labels (ex. label-1,label-2): [press Enter to skip]
```

```
~/actions-runner
./run.sh

√ Connected to GitHub

Current runner version: '2.333.0'
2026-03-30 16:06:38Z: Listening for Jobs
```

Self Hosted



Se ficar muito tempo sem usar ele é deletado sozinho!

Self Hosted

- Uses
  - Github actions marketplace
- Context

```
~/actions-runner
./run.sh

√ Connected to GitHub

Current runner version: '2.333.0'
2026-03-30 16:06:38Z: Listening for Jobs
2026-03-30 16:20:25Z: Running job: teste
2026-03-30 16:20:47Z: Job teste completed with result: Succeeded
```

```yaml
name: Self Runner maquina pessoal

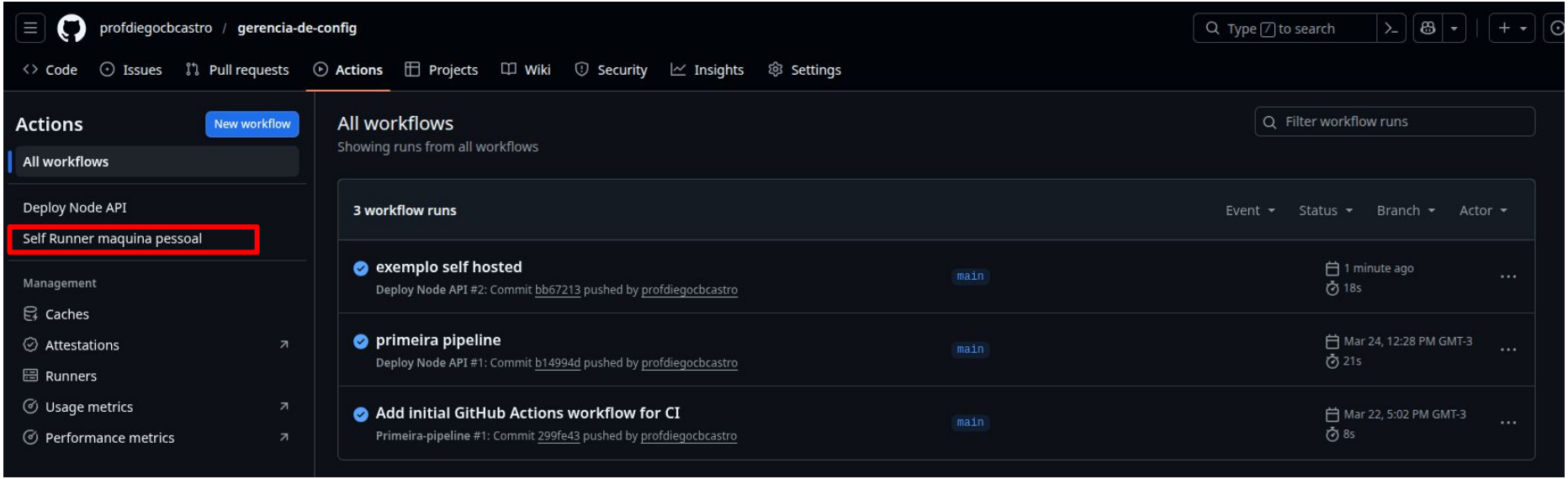
on:
  workflow_dispatch:

jobs:
  teste:
    runs-on: self-hosted

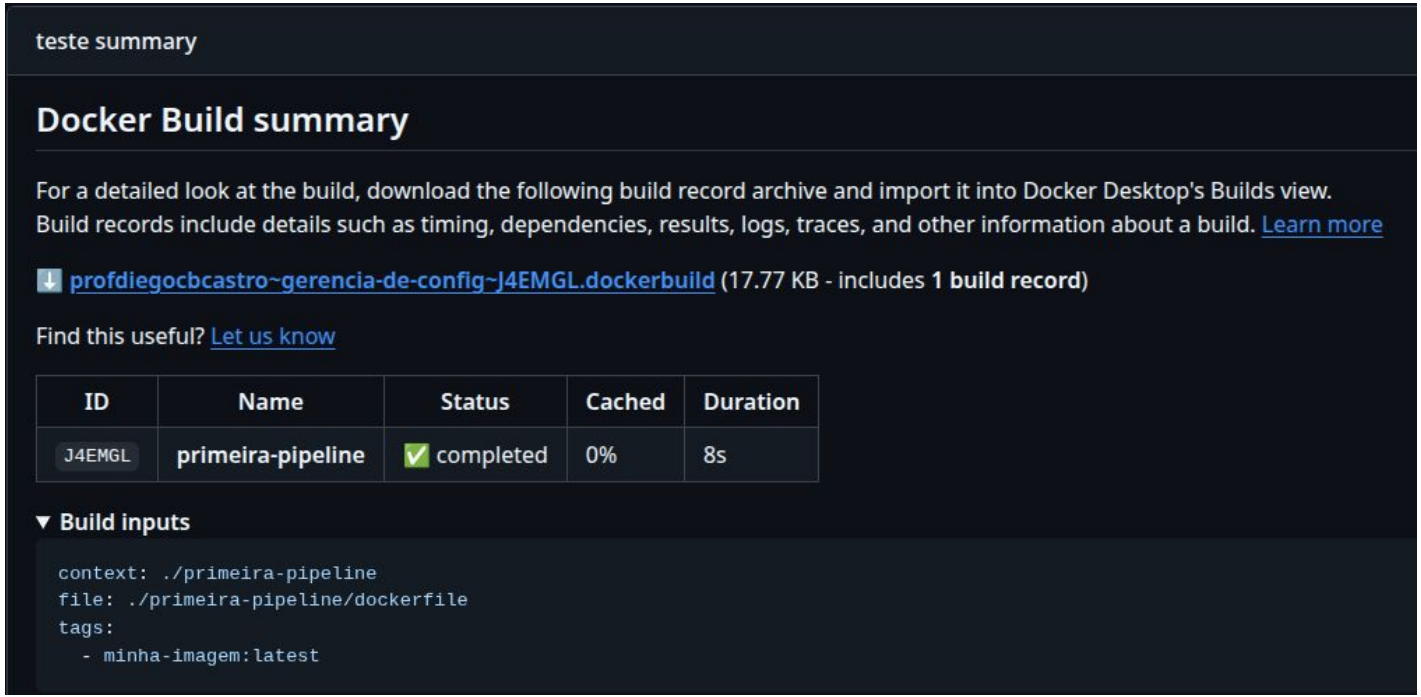
    steps:
      - name: Checkout
        uses: actions/checkout@v4

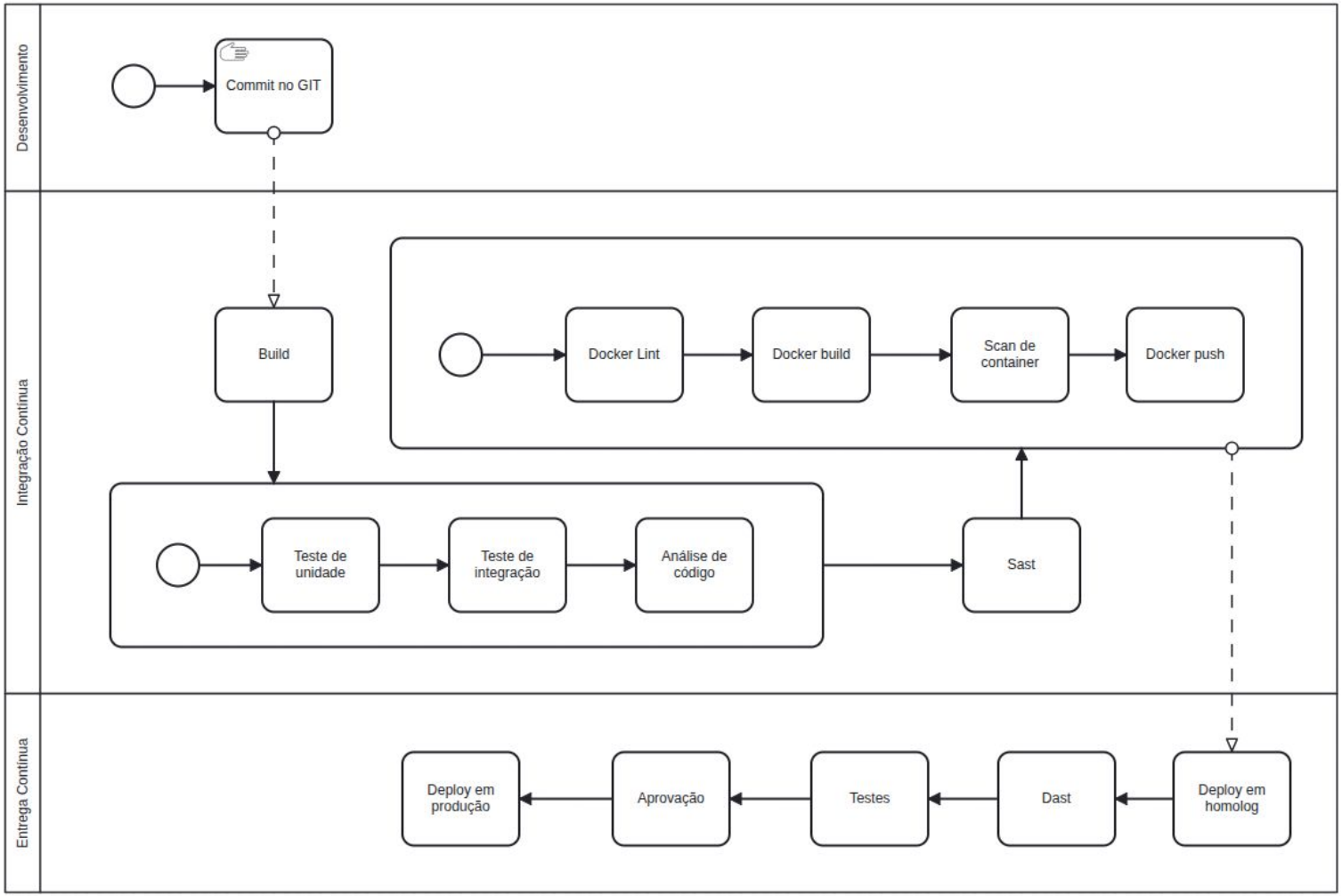
      - name: Build Docker
        uses: docker/build-push-action@v6
        with:
          context: ./primeira-pipeline
          file: ./primeira-pipeline/dockerfile
          push: false
          tags: minha-imagem:latest
```

Self Hosted


profdiegocbcastro / gerencia-de-config
Type / to search
Code
Issues
Pull requests
Actions
Projects
Wiki
Security
Insights
Settings
Actions
New workflow
All workflows
Deploy Node API
Self Runner maquina pessoal
Management
Caches
Attestations
Runners
Usage metrics
Performance metrics
All workflows
Showing runs from all workflows
Filter workflow runs
3 workflow runs
Event
Status
Branch
Actor
exemplo self hosted
Deploy Node API #2: Commit bb67213 pushed by profdiegocbcastro
main
1 minute ago
18s
primeira pipeline
Deploy Node API #1: Commit b14994d pushed by profdiegocbcastro
main
Mar 24, 12:28 PM GMT-3
21s
Add initial GitHub Actions workflow for CI
Primeira-pipeline #1: Commit 299fe43 pushed by profdiegocbcastro
main
Mar 22, 5:02 PM GMT-3
8s

Self Hosted

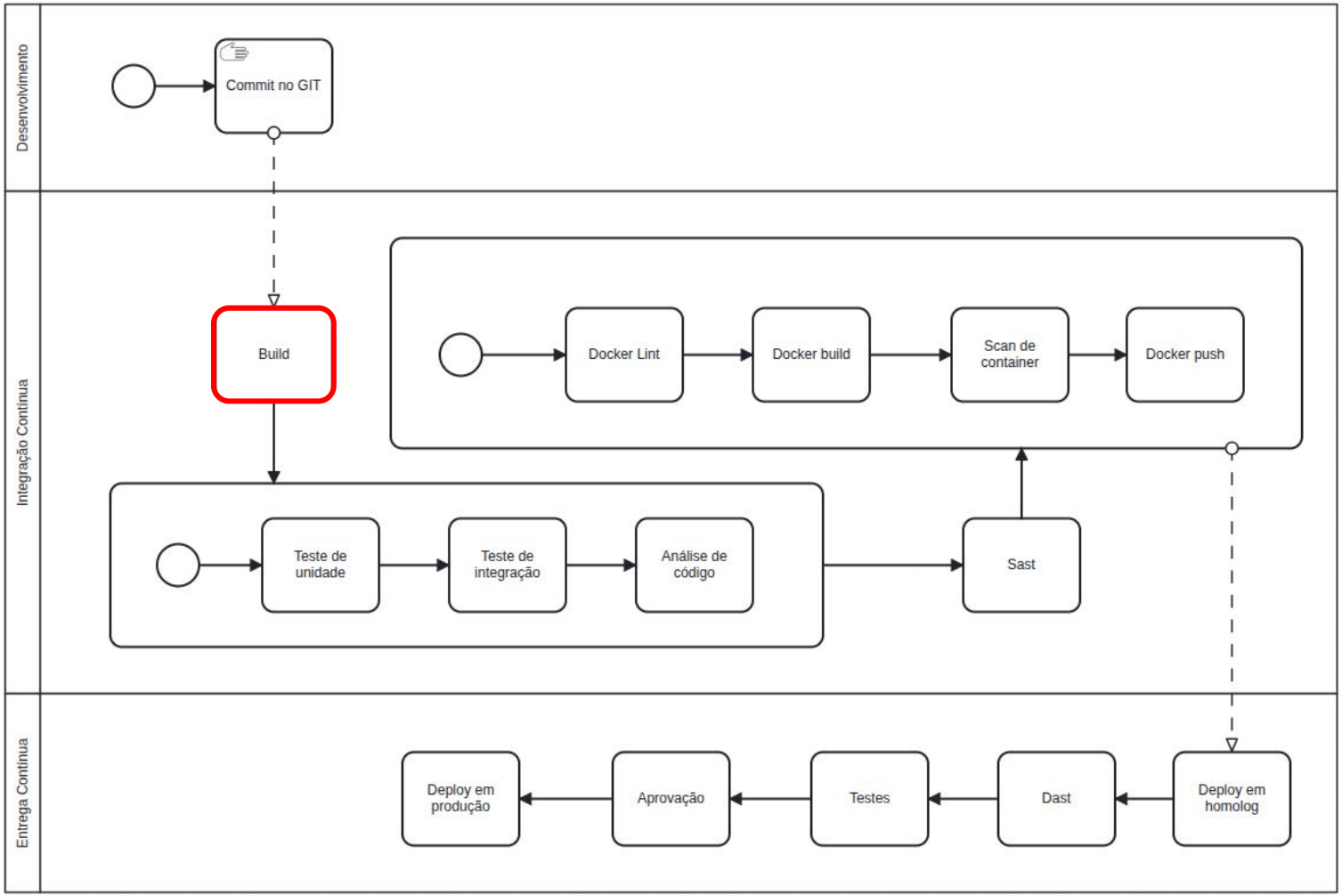

teste summary
Docker Build summary
For a detailed look at the build, download the following build record archive and import it into Docker Desktop's Builds view.
Build records include details such as timing, dependencies, results, logs, traces, and other information about a build. Learn more
profdiegocbcastro~gerencia-de-config~J4EMGL.dockerbuild (17.77 KB - includes 1 build record)
Find this useful? Let us know
ID
Name
Status
Cached
Duration
J4EMGL
primeira-pipeline
completed
0%
8s
Build inputs
context: ./primeira-pipeline
file: ./primeira-pipeline/dockerfile
tags:
- minha-imagem:latest


Desenvolvimento
Commit no GIT
Integração Contínua
Build
Docker Lint
Docker build
Scan de container
Docker push
Teste de unidade
Teste de integração
Análise de código
Sast
Entrega Contínua
Deploy em produção
Aprovação
Testes
Dast
Deploy em homolog

- Contexto:
  - Informações sobre a execução do fluxo de trabalho e sobre o evento que a disparou

https://docs.github.com/pt/actions/reference/workflows-and-actions/contexts#github-context

Nome da propriedade	Tipo	Descrição
`github`	`object`	Contexto de nível mais alto disponível em qualquer trabalho ou etapa de um fluxo de trabalho. Este objeto contém todas as propriedades listadas abaixo.
`github.action`	`string`	O nome da ação atualmente em execução ou a `id` de uma etapa. O GitHub remove caracteres especiais ou usa o nome `__run` quando a etapa atual executa um script sem uma `id`. Se você usar a mesma ação mais de uma vez no mesmo trabalho, o nome incluirá um sufixo com o número da sequência com o sublinhado antes dele. Por exemplo, o primeiro script que você executar terá o nome `__run`, e o segundo script será chamado `__run_2`. Da mesma forma, a segunda invocação de `actions/checkout` será `actionscheckout2`.
`github.action_path`	`string`	O caminho onde uma ação está localizada. Esta propriedade só é compatível com ações compostas. Você pode usar esse


Desenvolvimento
Commit no GIT
Integração Contínua
Build
Docker Lint
Docker build
Scan de container
Docker push
Teste de unidade
Teste de integração
Análise de código
Sast
Entrega Contínua
Deploy em produção
Aprovação
Testes
Dast
Deploy em homolog

- Build
  - Checkout
  - Instalar o node
- GitHub actions
  - https://github.com/actions/setup-node

```yaml
steps:
  - name: Checkout
    uses: actions/checkout@v5

  - name: Setup Node.js
    uses: actions/setup-node@v6
    with:
      node-version: '20'
```



```yaml
name: Segunda pipeline
run-name: Segunda pipeline executada por ${{ github.actor }}

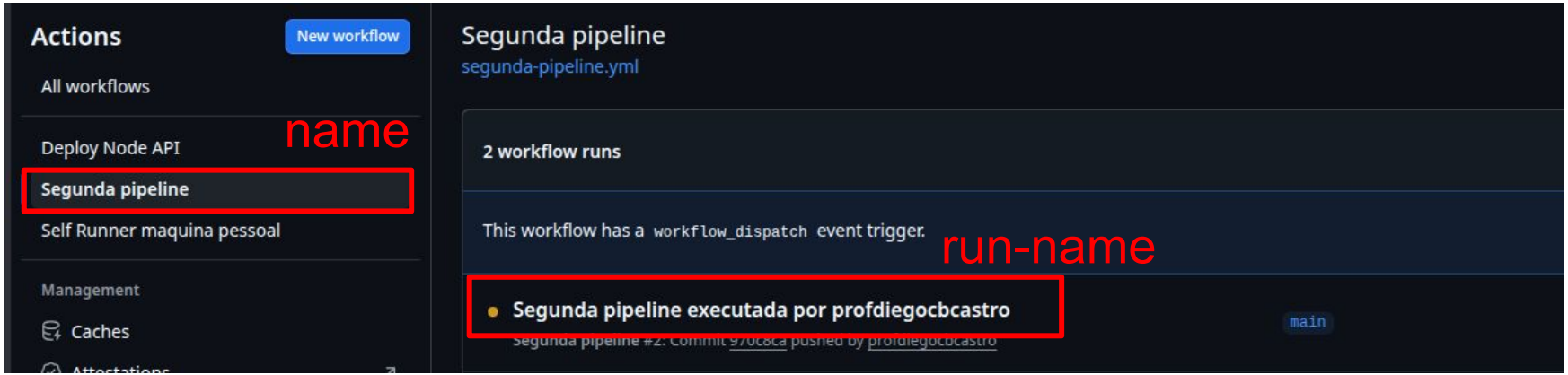
on:
  push:
    branches: [ main ]
  workflow_dispatch:

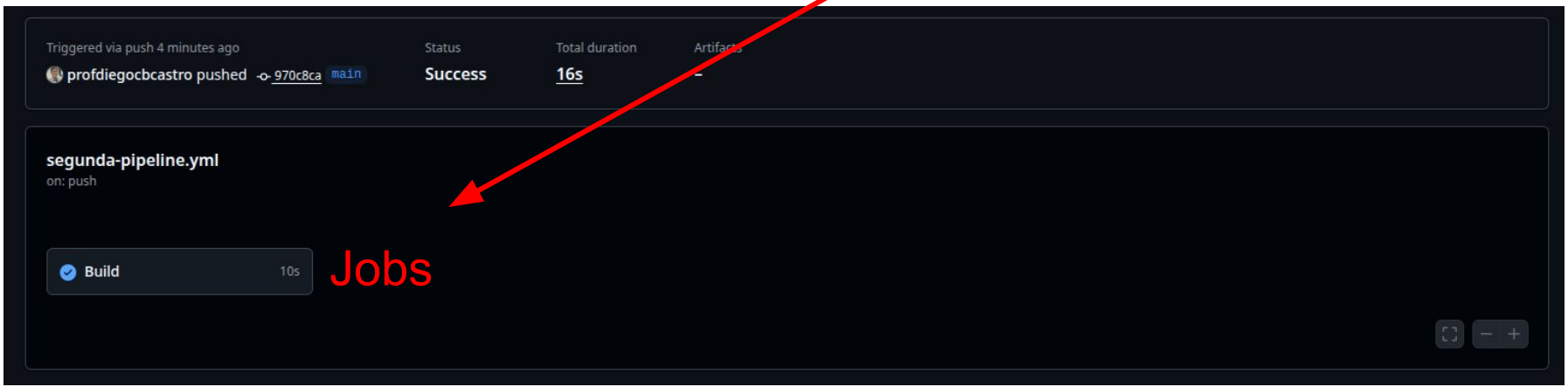
jobs:
  build:
    name: Build
    runs-on: ubuntu-latest

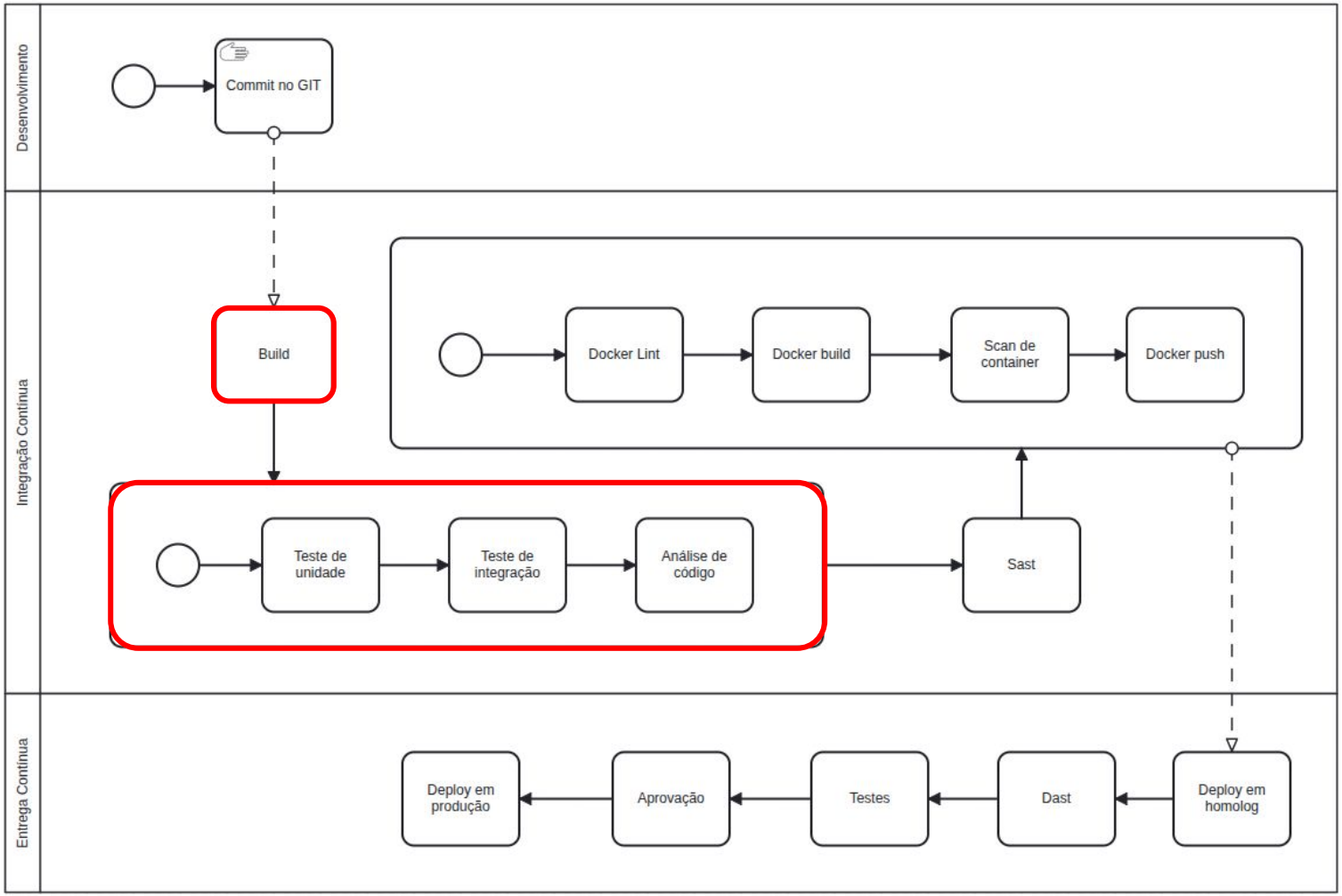
    steps:
      - name: Checkout
        uses: actions/checkout@v5

      - name: Instalar Node.js
        run: |
          sudo apt update
          sudo apt install -y nodejs npm

      - name: Verificar instalação
        run: |
          node -v
          npm -v
```


Actions
New workflow
All workflows
Deploy Node API
name
Segunda pipeline
Self Runner maquina pessoal
Management
Caches
Segunda pipeline
segunda-pipeline.yml
2 workflow runs
This workflow has a workflow_dispatch event trigger.
run-name
Segunda pipeline executada por profdiegocbcastro
main


Triggered via push 4 minutes ago
profdiegocbcastro pushed 970c8ca main
Status
Success
Total duration
16s
Artifacts
segunda-pipeline.yml
on: push
Build 10s
Jobs


Desenvolvimento
Commit no GIT
Integração Contínua
Build
Docker Lint
Docker build
Scan de container
Docker push
Teste de unidade
Teste de integração
Análise de código
Sast
Entrega Contínua
Deploy em produção
Aprovação
Testes
Dast
Deploy em homolog

- Cria um workflow reaproveitável pois outros projetos podem se utilizar dele
  - workflow_call
- working-directory
  - Passa o diretório onde o comando precisa ser executado
  - Muito utilizado para monorepo

```yaml
workflow-testes:
  uses: ./.github/workflows/testes-segunda-pipeline.yml
  needs: build
```

```yaml
name: Testes da Segunda Pipeline

on:
  workflow_call:

defaults:
  run:
    working-directory: ./segunda-pipeline

jobs:
  unit-tests:
    name: Testes Unitários
    runs-on: ubuntu-latest

    steps:
      - name: Checkout
        uses: actions/checkout@v5

      - name: Setup Node.js
        uses: actions/setup-node@v6
        with:
          node-version: '20'

      - name: Install Dependencies
        working-directory: ./segunda-pipeline
        run: npm install

      - name: Run Unit Tests
        working-directory: ./segunda-pipeline
        run: npm run test:unit
```

- Cria um workflow reaproveitável pois outros projetos podem se utilizar dele
  - workflow_call
- working-directory
  - Passa o diretório onde o comando precisa ser executado
  - Muito utilizado para monorepo

```yaml
workflow-testes:
  uses: ./.github/workflows/testes-segunda-pipeline.yml
  needs: build
```

```yaml
e2e-tests:
  name: Testes End-to-End
  runs-on: ubuntu-latest
  needs: unit-tests

  steps:
    - name: Checkout
      uses: actions/checkout@v5

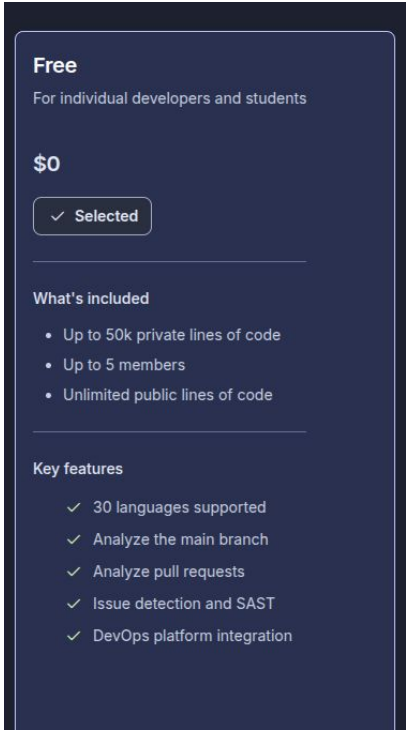
    - name: Setup Node.js
      uses: actions/setup-node@v6
      with:
        node-version: '20'

    - name: Install Dependencies
      working-directory: ./segunda-pipeline
      run: npm install

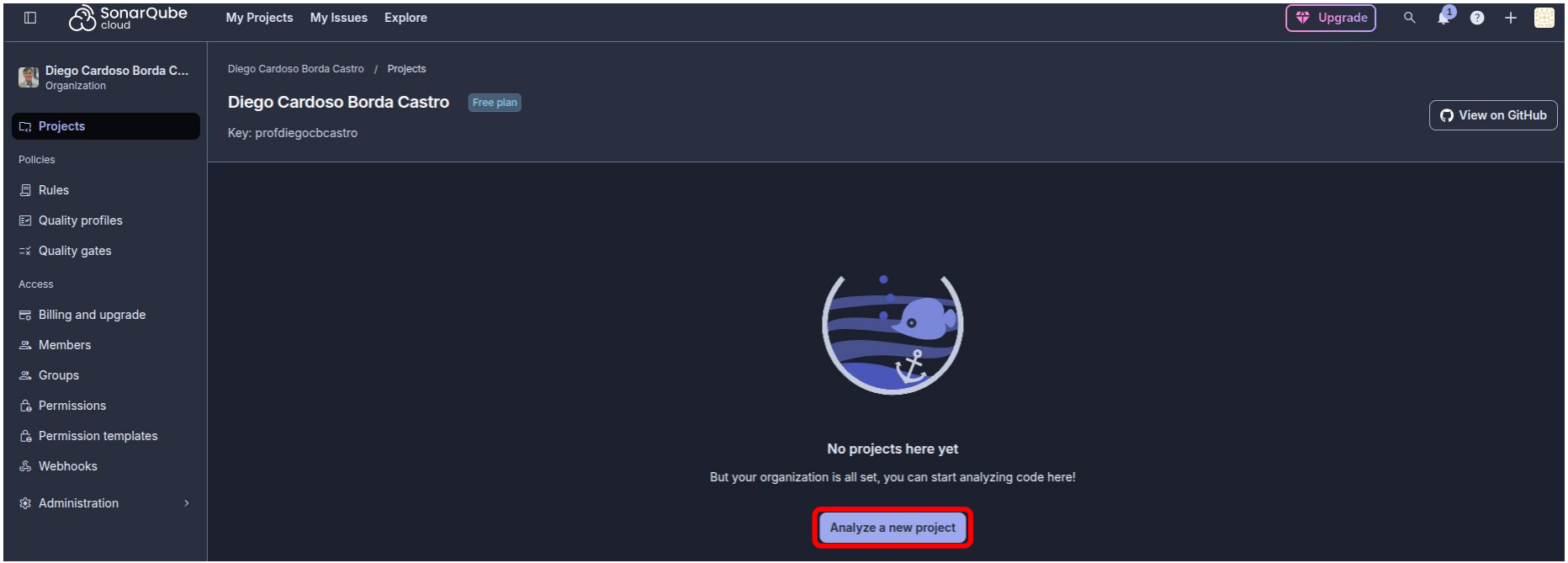
    - name: Run E2E Tests
      working-directory: ./segunda-pipeline
      run: npm run test:e2e
```

SonarQube

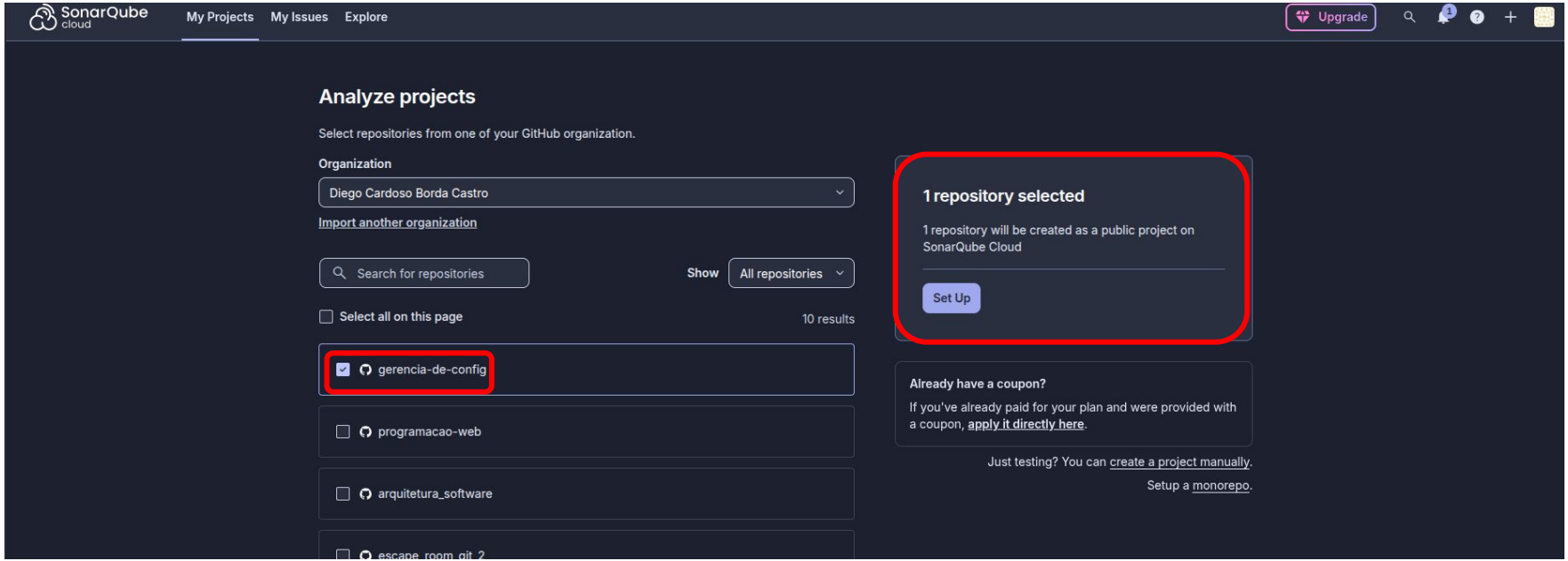
- Ferramenta de análise estática de código
- Detecta problemas sem executar a aplicação
  - Foco em segurança + qualidade de código
  - 🔐 Vulnerabilidades (SQL Injection, XSS, etc.)
  - 🐞 Bugs
  - 🧹 Code Smells (más práticas)
  - 📊 Cobertura de testes
- https://sonarcloud.io



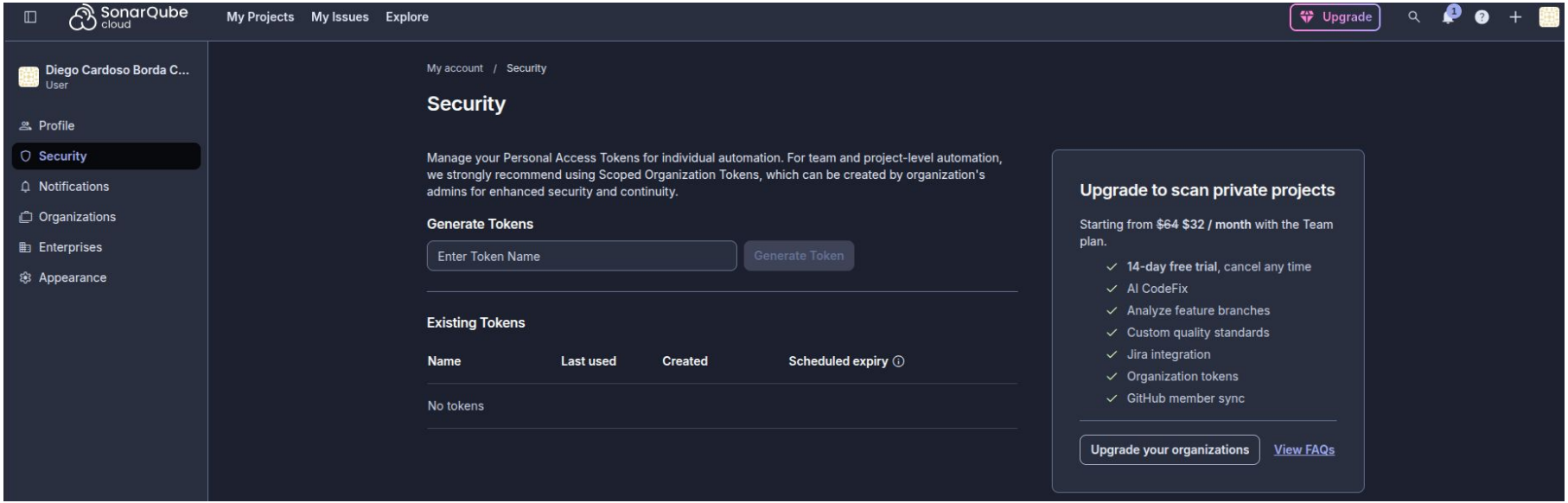
SonarQube


SonarQube cloud
My Projects
My Issues
Explore
Upgrade
Diego Cardoso Borda C...
Organization
Projects
Policies
Rules
Quality profiles
Quality gates
Access
Billing and upgrade
Members
Groups
Permissions
Permission templates
Webhooks
Administration
Diego Cardoso Borda Castro / Projects
Diego Cardoso Borda Castro
Free plan
Key: profdiegocbcastro
View on GitHub
No projects here yet
But your organization is all set, you can start analyzing code here!
Analyze a new project

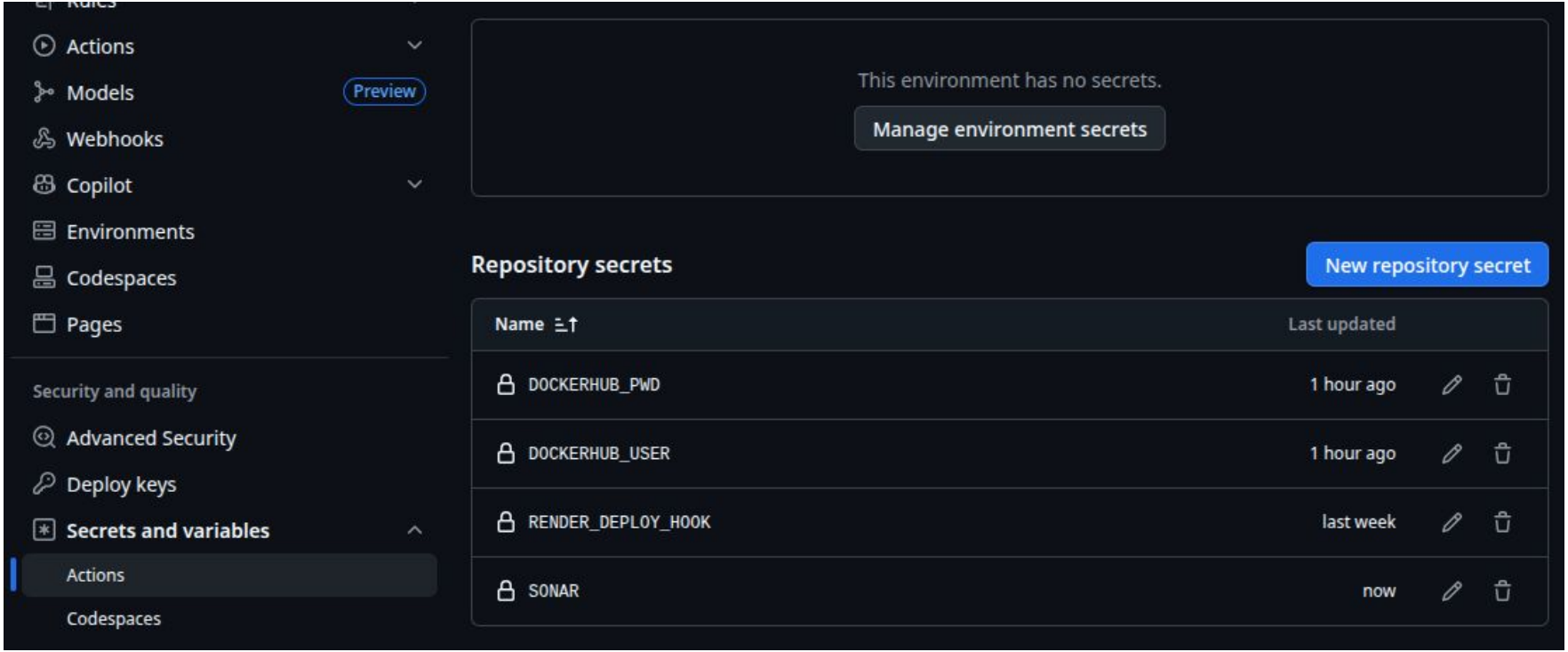
SonarQube


SonarQube cloud
My Projects
My Issues
Explore
Upgrade
Analyze projects
Select repositories from one of your GitHub organization.
Organization
Diego Cardoso Borda Castro
Import another organization
Search for repositories
Show
All repositories
Select all on this page
10 results
gerencia-de-config
programacao-web
arquitetura_software
escape_room_git_2
1 repository selected
1 repository will be created as a public project on SonarQube Cloud
Set Up
Already have a coupon?
If you've already paid for your plan and were provided with a coupon, apply it directly here.
Just testing? You can create a project manually.
Setup a monorepo.

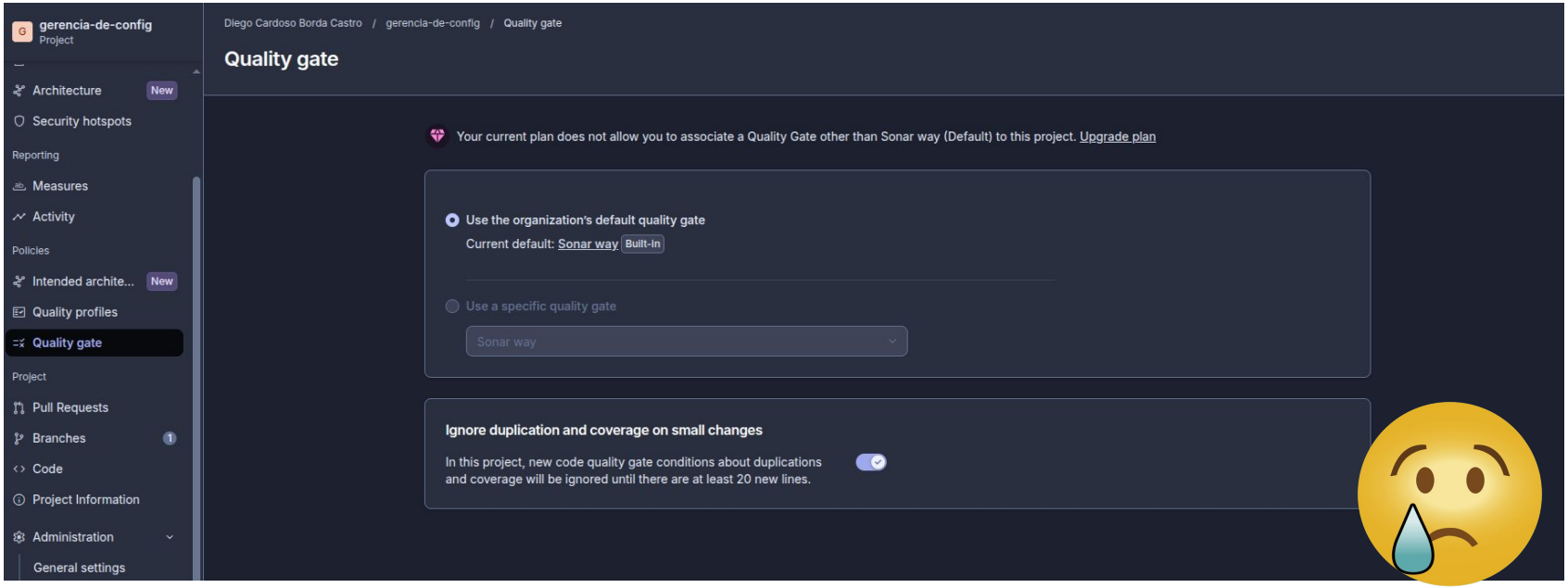
SonarQube


SonarQube cloud
My Projects
My Issues
Explore
Upgrade
Diego Cardoso Borda C...
User
Profile
Security
Notifications
Organizations
Enterprises
Appearance
My account / Security
Security
Manage your Personal Access Tokens for individual automation. For team and project-level automation, we strongly recommend using Scoped Organization Tokens, which can be created by organization's admins for enhanced security and continuity.
Generate Tokens
Enter Token Name
Generate Token
Existing Tokens
Name
Last used
Created
Scheduled expiry
No tokens
Upgrade to scan private projects
Starting from $64 $32 / month with the Team plan.
14-day free trial, cancel any time
AI CodeFix
Analyze feature branches
Custom quality standards
Jira integration
Organization tokens
GitHub member sync
Upgrade your organizations
View FAQs

SonarQube


Actions
Models
Preview
Webhooks
Copilot
Environments
Codespaces
Pages
Security and quality
Advanced Security
Deploy keys
Secrets and variables
Actions
Codespaces
This environment has no secrets.
Manage environment secrets
Repository secrets
New repository secret
Name
Last updated
DOCKERHUB_PWD
1 hour ago
DOCKERHUB_USER
1 hour ago
RENDER_DEPLOY_HOOK
last week
SONAR
now

SonarQube


gerencia-de-config
Project
Architecture
New
Security hotspots
Reporting
Measures
Activity
Policies
Intended archite...
New
Quality profiles
Quality gate
Project
Pull Requests
Branches
1
Code
Project Information
Administration
General settings
Diego Cardoso Borda Castro / gerencia-de-config / Quality gate
Quality gate
Your current plan does not allow you to associate a Quality Gate other than Sonar way (Default) to this project. Upgrade plan
Use the organization's default quality gate
Current default: Sonar way
Built-in
Use a specific quality gate
Sonar way
Ignore duplication and coverage on small changes
In this project, new code quality gate conditions about duplications and coverage will be ignored until there are at least 20 new lines.

SonarQube

```yaml
on:
  workflow_call:
    secrets:
      SONAR_TOKEN:
        required: true
```

```yaml
workflow-testes:
  uses: ./.github/workflows/testes-segunda-pipeline.yml
  needs: build
  secrets:
    SONAR_TOKEN: ${{ secrets.SONAR_TOKEN }}
```

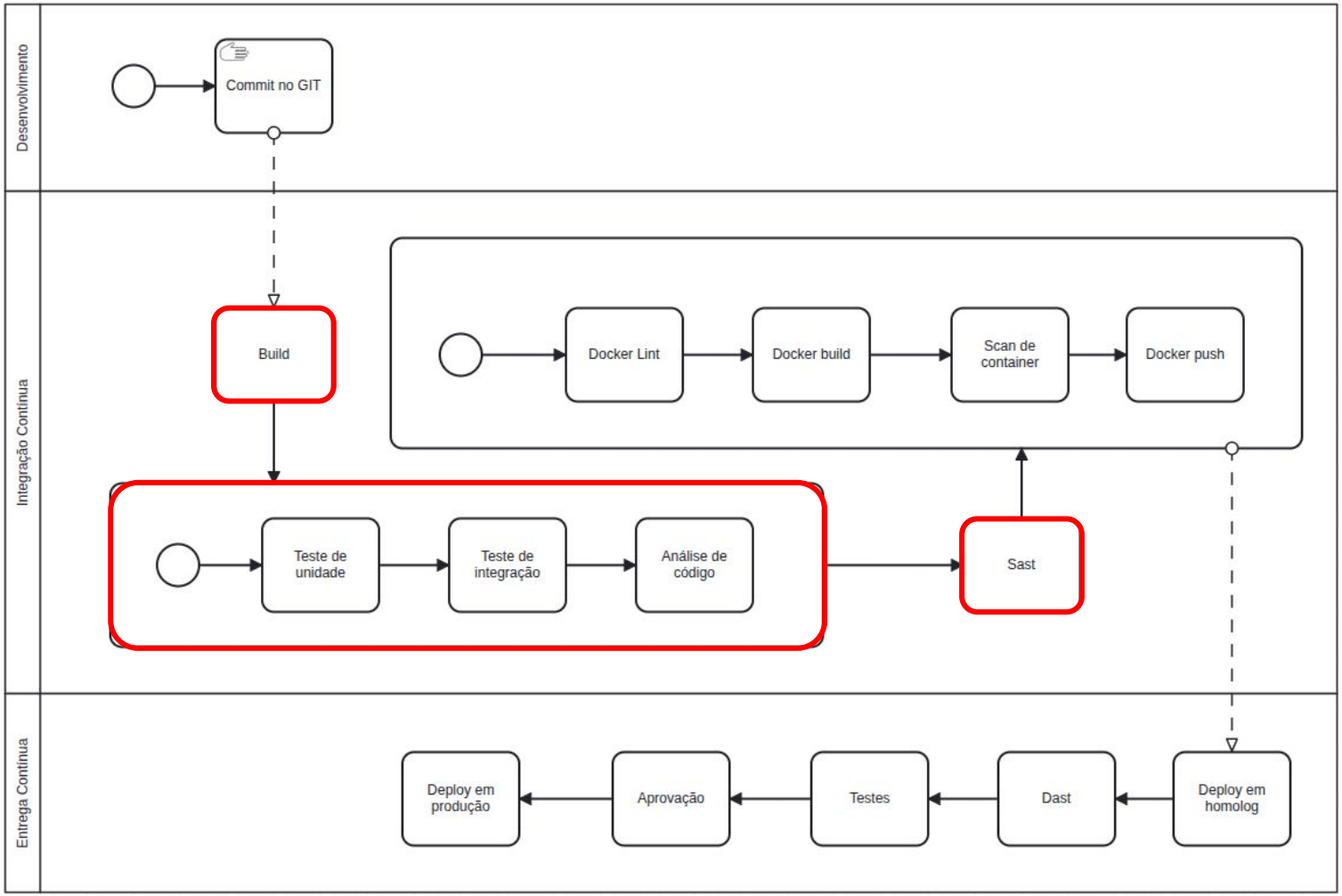
```yaml
analise-codigo:
  name: Análise de Código com SonarQube
  runs-on: ubuntu-latest
  needs: e2e-tests

  steps:
    - name: Verificar Quality Gate
      uses: SonarSource/sonarcloud-github-action@v2
      with:
        args: >
          -Dsonar.projectKey=profdiegocbcastro_gerencia-de-config
          -Dsonar.organization=profdiegocbcastro
          -Dsonar.qualitygate.wait=true
        timeout-minutes: 5
        env:
          SONAR_TOKEN: ${{ secrets.SONAR_TOKEN }}
```

SonarQube

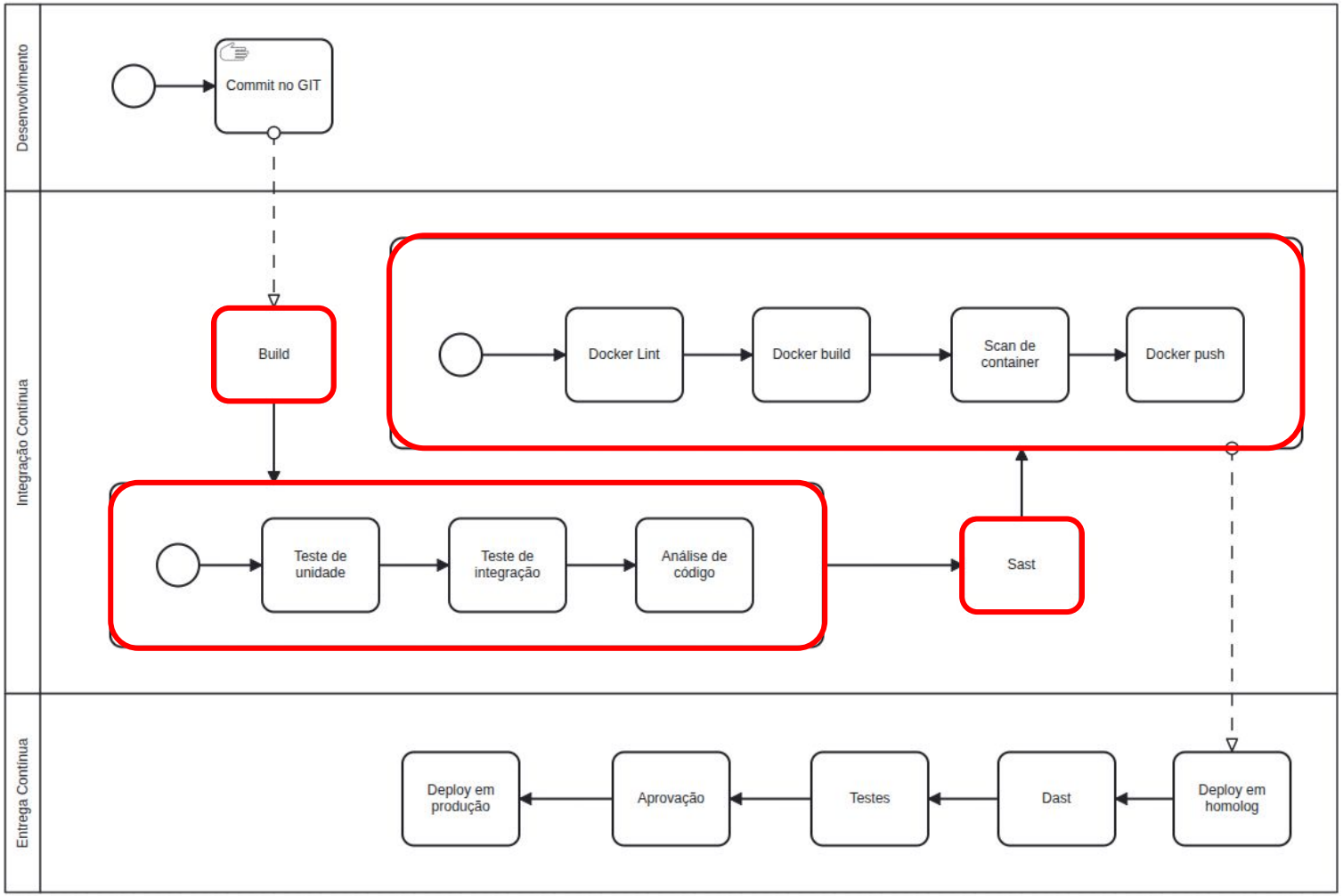
- Sem needs roda em paralelo




Desenvolvimento
Commit no GIT
Integração Contínua
Build
Docker Lint
Docker build
Scan de container
Docker push
Teste de unidade
Teste de integração
Análise de código
Sast
Entrega Contínua
Deploy em produção
Aprovação
Testes
Dast
Deploy em homolog

SAST

- SAST (Static Application Security Testing)
  - Teste estático de segurança
  - Análise de código ou bytecode, sem execução
  - Ideal para fase de desenvolvimento
  - Detecção de vulnerabilidade de forma precoce
  - Riscos envolvidos
    - Hardcoded secrets (chaves/API Keys)
    - Injeção (SQLi, XSS, Command)
    - Problemas de validação e sanitização
    - Cobertura parcial se houver lógica dinâmica
    - Ex.: Semgrep, SonarQube, Checkmarx, Fortify, Gitleaks, etc


Desenvolvimento
Commit no GIT
Integração Contínua
Build
Docker Lint
Docker build
Scan de container
Docker push
Teste de unidade
Teste de integração
Análise de código
Sast
Entrega Contínua
Deploy em produção
Aprovação
Testes
Dast
Deploy em homolog

```yaml
release:
  name: Criação de Release
  runs-on: ubuntu-latest
  needs: workflow-testes

  steps:
    - name: Obtendo o código do projeto
      uses: actions/checkout@v5

    - name: Build da imagem Docker
      uses: docker/build-push-action@v6
      with:
        push: false
        context: ./segunda-pipeline
        file: segunda-pipeline/dockerfile
        tags: ${{ secrets.DOCKERHUB_USER }}/segunda-pipeline:latest

    - name: Scan de vulnerabilidades com Trivy
      uses: aquasecurity/trivy-action@master
      with:
        image-ref: ${{ secrets.DOCKERHUB_USER }}/segunda-pipeline:latest
        format: 'table'
        exit-code: '1'
        ignore-unfixed: true
        vuln-type: 'os,library'
        severity: 'CRITICAL,HIGH'
```

```yaml
    - name: Upload do relatório Trivy
      uses: actions/upload-artifact@v4
      with:
        name: trivy-report
        path: trivy-report.json

    - name: Upload do relatório Trivy
      uses: actions/upload-artifact@v4
      with:
        name: trivy-report
        path: trivy-report.json

    - name: Efetuando o Login no Docker Hub
      uses: docker/login-action@v3
      with:
        username: ${{ secrets.DOCKERHUB_USER }}
        password: ${{ secrets.DOCKERHUB_PWD }}
```

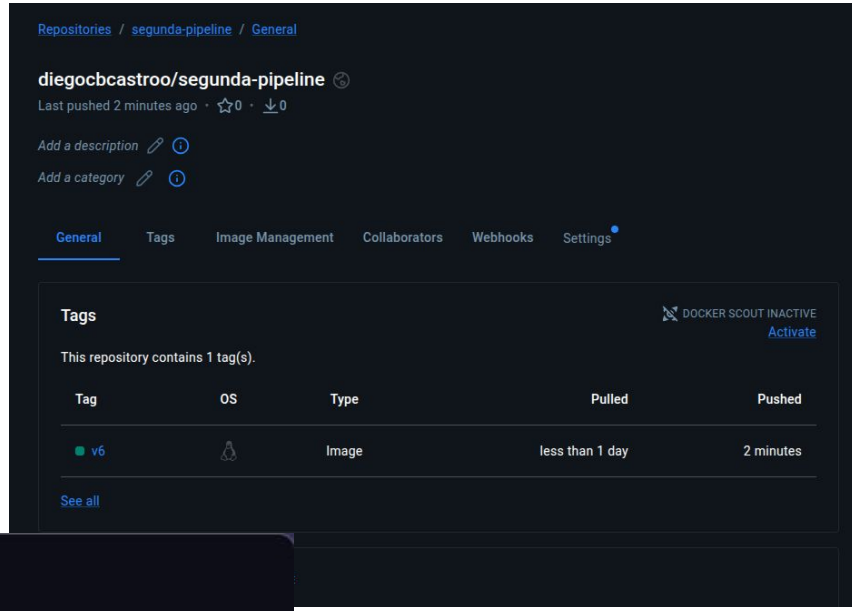
Total: 11 (HIGH: 11, CRITICAL: 0)

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
cross-spawn (package.json)	CVE-2024-21538	HIGH	fixed	7.0.3	7.0.5, 6.0.6	cross-spawn: regular expression denial of service https://avd.aquasec.com/nvd/cve-2024-21538
glob (package.json)	CVE-2025-64756			10.4.2	11.1.0, 10.5.0	glob: glob: Command Injection Vulnerability via Malicious Filenames https://avd.aquasec.com/nvd/cve-2025-64756
minimatch (package.json)	CVE-2026-26996			9.0.5	10.2.1, 9.0.6, 8.0.5, 7.4.7, 6.2.1, 5.1.7, 4.2.4, 3.1.3	minimatch: minimatch: Denial of Service via specially crafted glob patterns https://avd.aquasec.com/nvd/cve-2026-26996
	CVE-2026-27904			10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.4	minimatch: Minimatch: Denial of Service via catastrophic backtracking in glob expressions

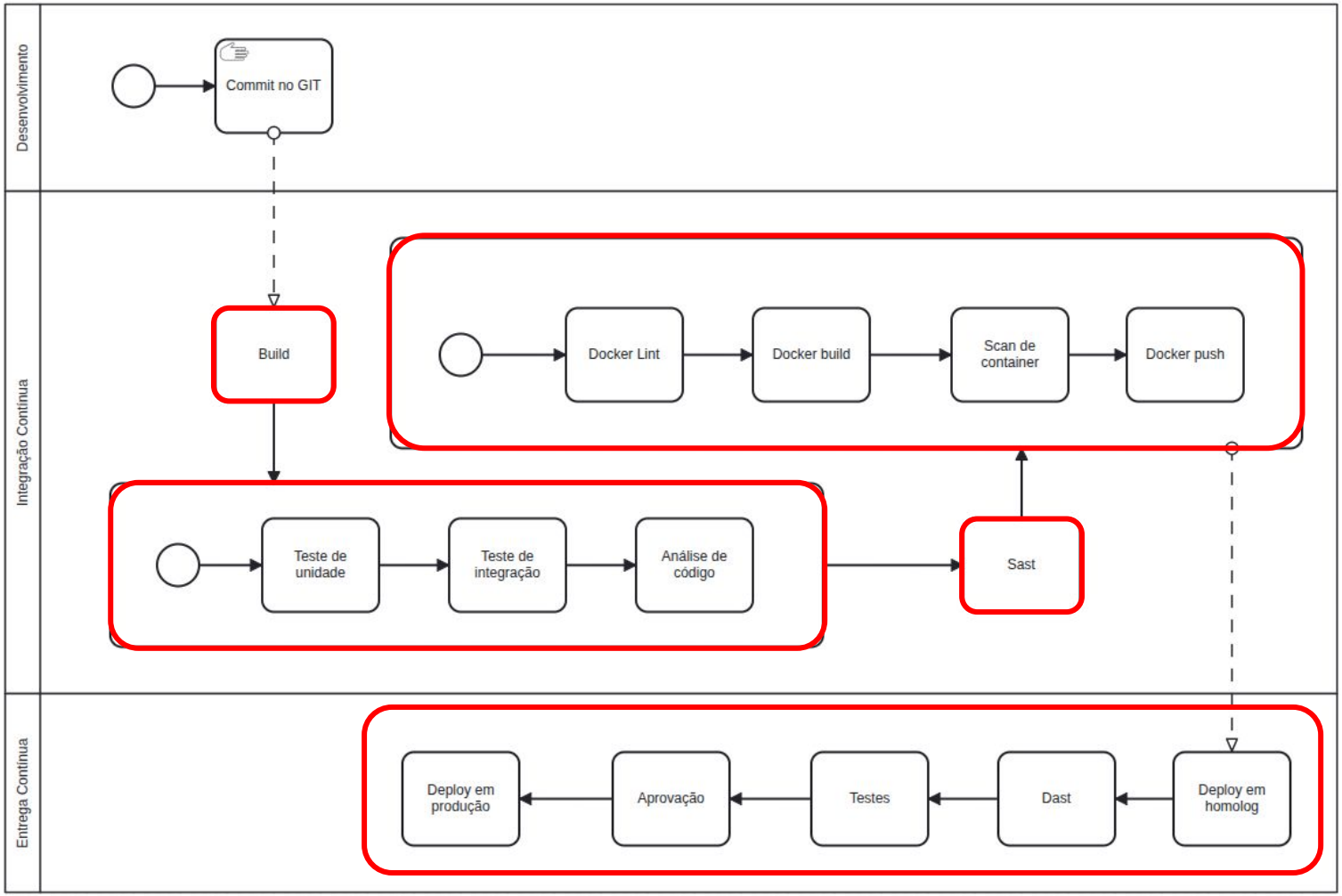
segunda-pipeline.yml
on: workflow_dispatch

Build 8s → workflo... / Testes Unitários 15s → workfl... / Testes End-to-End 15s → w.../ Análise de Código co... 31s → Criação de Release 1m 14s

- No final subimos a versão para o docker hub
- Finalizando nossa pipeline de CI




```yaml
- name: Build e Push da Imagem Docker
  uses: docker/build-push-action@v6
  with:
    push: true
    context: ./segunda-pipeline
    file: segunda-pipeline/dockerfile
    tags: ${{ secrets.DOCKERHUB_USER }}/segunda-pipeline:v${{ github.run_number }}
```


Desenvolvimento
Commit no GIT
Integração Contínua
Build
Docker Lint
Docker build
Scan de container
Docker push
Teste de unidade
Teste de integração
Análise de código
Sast
Entrega Contínua
Deploy em produção
Aprovação
Testes
Dast
Deploy em homolog

DAST

- DAST (Dynamic Application Security Testing)
  - Teste a aplicação rodando
  - Como um usuário externo
  - Simula ataques reais sem acesso ao código
  - Ideal para ambientes de staging ou produção controlada
- Riscos envolvidos
  - Falhas de autenticação/autorização
  - Exposição de dados
  - Validação fraca
  - Detecção de configurações inseguras (headers, cors)
  - Ex.: OWASP ZAP, Burp Suite, StackHawk, Probely

Deploy hom + DAST

```yaml
name: Segunda pipeline
run-name: Segunda pipeline executada por ${{ github.actor }}

on: ...

jobs:
  build: ...

  workflow-testes: ...

  release: ...

  deploy-homolog:
    uses: ./.github/workflows/Deploy-segunda-pipeline.yml
    needs: build
    secrets:
      RENDER_DEPLOY_HOOK: ${{ secrets.RENDER_DEPLOY_HOOK }}
```

```yaml
name: Deploy Homologação + DAST

on:
  workflow_call:
    secrets:
      RENDER_DEPLOY_HOOK:
        required: true

jobs:
  deploy-homolog:
    name: Deploy em Homolog
    runs-on: ubuntu-latest

    steps:
      - name: Deploy no Render
        run: curl -X POST ${{ secrets.RENDER_DEPLOY_HOOK }}

  dast:
    name: DAST com OWASP ZAP
    runs-on: ubuntu-latest
    needs: deploy-homolog

    steps:
      - name: Checkout
        uses: actions/checkout@v5

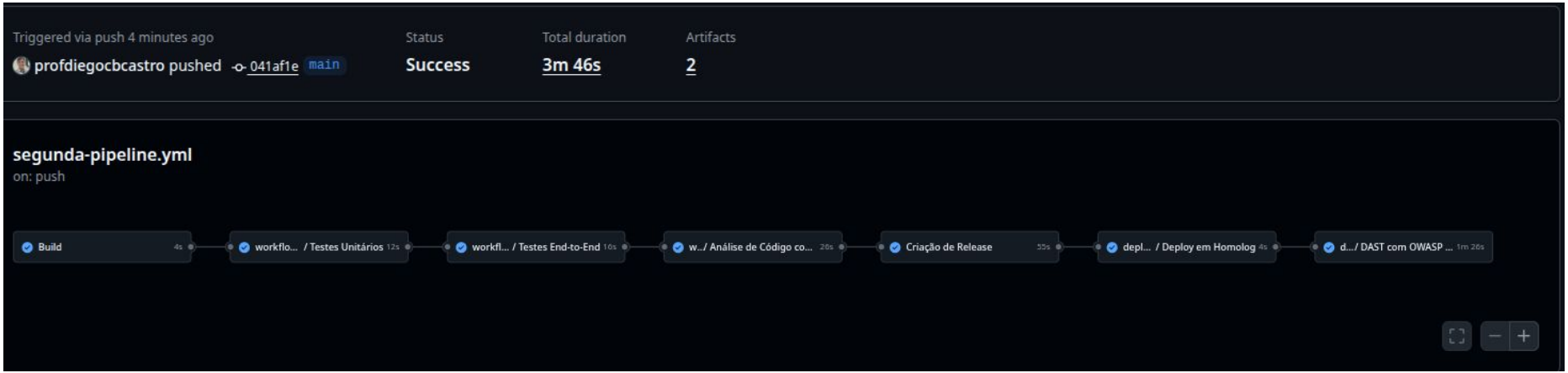
      - name: Corrigir permissões
        run: chmod -R 777 .

      - name: ZAP Scan
        uses: zaproxy/action-baseline@v0.12.0
        with:
          target: https://gerencia-de-config.onrender.com
          fail_action: true
```

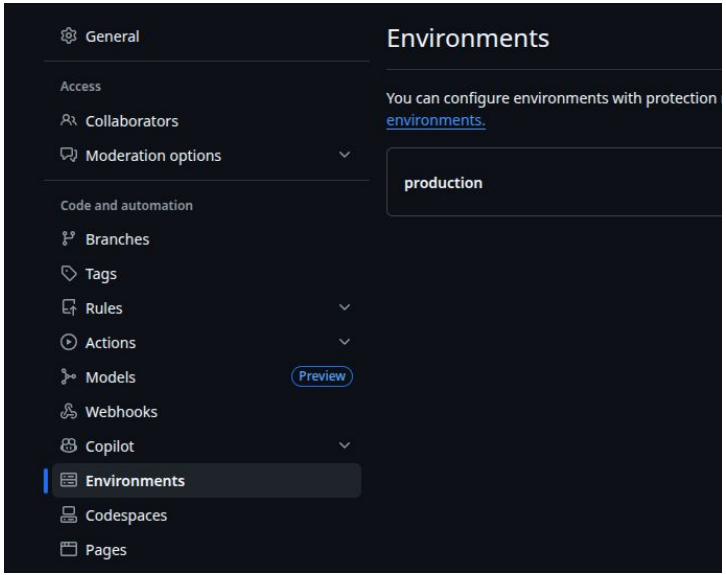
Deploy hom + DAST

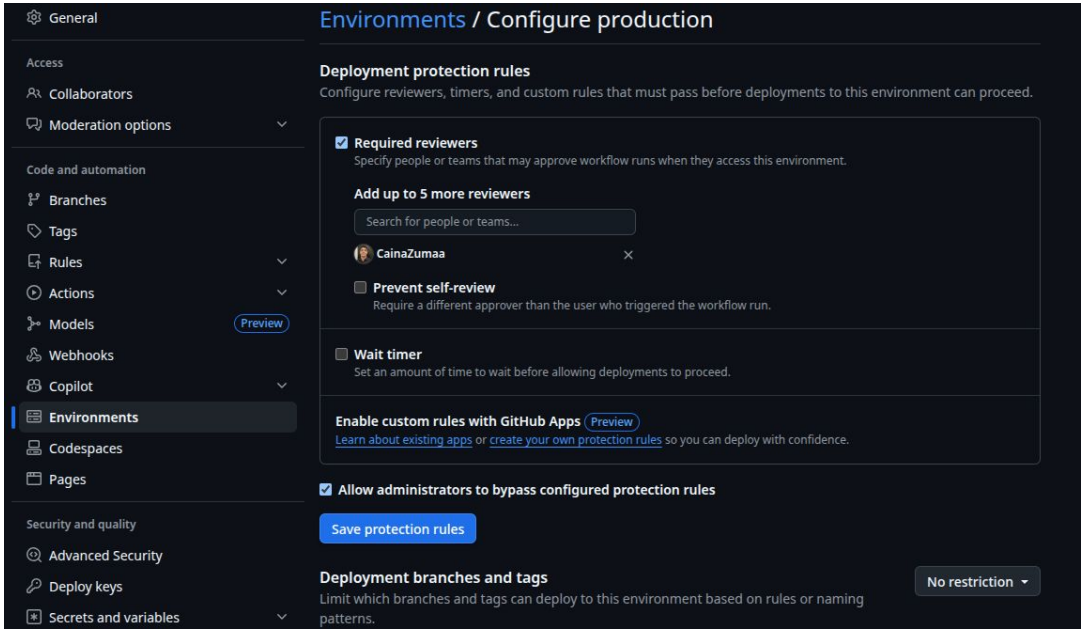
```
86  WARN-NEW: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) [10037] x 3
87          https://gerencia-de-config.onrender.com (200 OK)
88          https://gerencia-de-config.onrender.com/robots.txt (404 Not Found)
89          https://gerencia-de-config.onrender.com/sitemap.xml (404 Not Found)
90  WARN-NEW: Content Security Policy (CSP) Header Not Set [10038] x 1
91          https://gerencia-de-config.onrender.com (200 OK)
92  WARN-NEW: Storable and Cacheable Content [10049] x 3
93          https://gerencia-de-config.onrender.com (200 OK)
94          https://gerencia-de-config.onrender.com/robots.txt (404 Not Found)
95          https://gerencia-de-config.onrender.com/sitemap.xml (404 Not Found)
96  WARN-NEW: CSP: Failure to Define Directive with No Fallback [10055] x 2
97          https://gerencia-de-config.onrender.com/robots.txt (404 Not Found)
98          https://gerencia-de-config.onrender.com/sitemap.xml (404 Not Found)
99  WARN-NEW: Permissions Policy Header Not Set [10063] x 3
100         https://gerencia-de-config.onrender.com (200 OK)
101         https://gerencia-de-config.onrender.com/robots.txt (404 Not Found)
102         https://gerencia-de-config.onrender.com/sitemap.xml (404 Not Found)
103 WARN-NEW: Cross-Origin-Embedder-Policy Header Missing or Invalid [90004] x 3
104         https://gerencia-de-config.onrender.com (200 OK)
105         https://gerencia-de-config.onrender.com (200 OK)
106         https://gerencia-de-config.onrender.com (200 OK)
107 FAIL-NEW: 0     FAIL-INPROG: 0  WARN-NEW: 10    WARN-INPROG: 0  INFO: 0 IGNORE: 0       PASS: 57
108 [info] By default ZAP Docker container will fail if it identifies any alerts during the scan!
109 Error: Scan action failed as ZAP has identified alerts, starting to analyze the results. Error: The process '/usr/bin/docker' failed with exit code 2
110 Alerts present in the current report: true
111 Error: Resource not accessible by integration - https://docs.github.com/rest/issues/issues#create-an-issue
```

Deploy hom + DAST

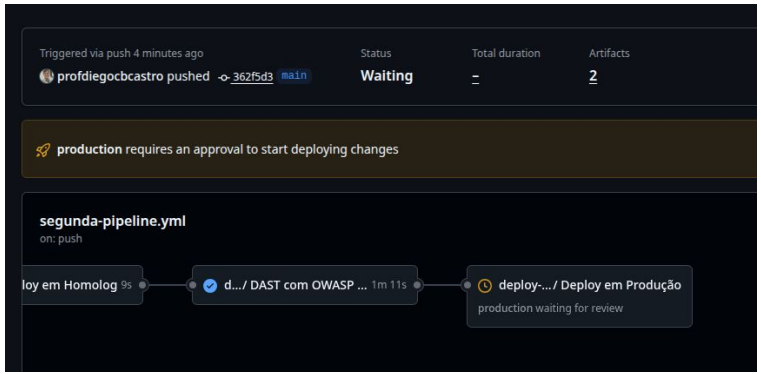


Deploy Produção





Deploy Produção




```yaml
name: Deploy Produção

on:
  workflow_call:
      secrets:
        RENDER_DEPLOY_HOOK:
          required: true

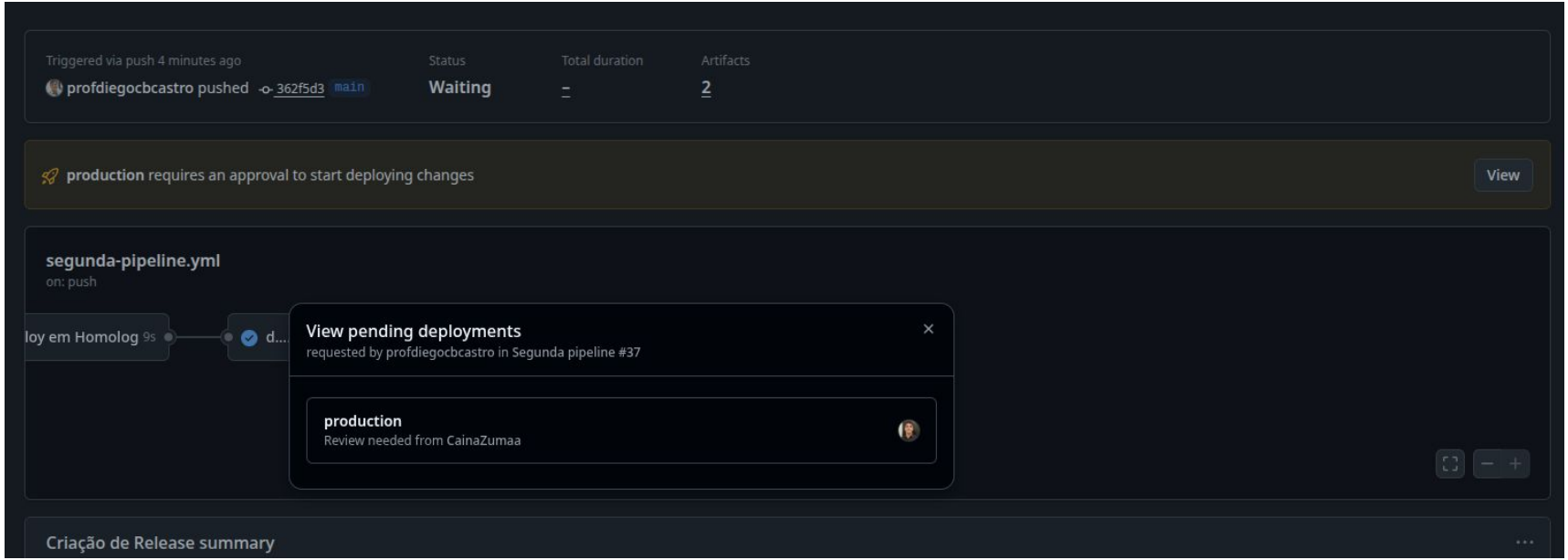
jobs:
  deploy-prod:
    name: Deploy em Produção
    runs-on: ubuntu-latest

    environment:
      name: production
      url: https://gerencia-de-config.onrender.com

    steps:
      - name: Deploy no Render (PROD)
        run: curl -X POST ${{ secrets.RENDER_DEPLOY_HOOK }}
```

```yaml
deploy-prod:
  uses: ./.github/workflows/deploy-prod-segunda-pipeline.yml
  needs: deploy-homolog
  secrets:
    RENDER_DEPLOY_HOOK: ${{ secrets.RENDER_DEPLOY_HOOK }}
```

Deploy Produção



Deploy Produção

